

ЛЕКЦИЯ 7

**Аспекти на администрирането -
права, разрешения и групови
политики в MS AD. Мрежово
споделяне на данни. SMB протокол.**

МРЕЖОВО АДМИНИСТРИРАНЕ

Задачи на мрежовото администриране

- Осигуряване изпълнението на политиката за сигурност на организацията;
- Назначаване на привилегии;
- Назначаване на определените от бизнеса права / разрешения за достъп до мрежови ресурси;
- Оптимално разполагане на мрежовите ресурси;
- Осигуряване на работната среда на потребителите;
- Гарантиране на определената сигурност, цялостност и наличност на информацията;

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (1)

- Целта на администрирането с групови политики е лесно и централизирано налагане на правила върху компютри и потребители, домейни и организационни единици;
- С груповите политики може да се управлява както поведението на работните станции и сървъри, така и на потребителите в организацията. Чрез прилагането на десетки хиляди настройки, на практика може да се управлява всичко, от времето на включване на скрийнсейвъра до управлението на захранването на работната станция;

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (2)

➤ Обват на действие:

- Могат да бъдат насочени към компютри и потребители, сайтове, домейни и OU;
- Могат да бъдат приложени към потребители, компютри или групи от тях;
- Могат да се задават стойности на променливи, които автоматично да се променят при определени ситуации;
- Могат да се стартират скриптове при login или logoff, както и при стартиране или изгасяне на компютрите;

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (3)

➤ Обхват на действие:

- Настройки на регистрите – *enable, disable, unconfigured*;

Трябва да се внимава с опциите: “*Disable Access to This Option.*”

Ако се избере *disable* --> *enable*

Ако се избере *enable* --> *disable*

- Настройки по отношение на сигурност;
- Преференции на политиките;
- Инсталация на софтуер;

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (4)

➤ Как работят груповите политики?

- Политики прилагани за компютър;
- Политики прилагани за потребител;
- Груповата политика се създава като самостоятелен обект (Group Policy Object – GPO) в AD ;
- Всеки един GPO обект може да бъде свързан **един** или **повече пъти** към **сайтове, домейни** или **организационни единици**;
- GPO не могат да се свързват с контейнери, но за потребителите и групите от потребители, които са в контейнера ще се приложат политиките свързани с домейна или сайта;

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (5)

➤ Как работят груповите политики?

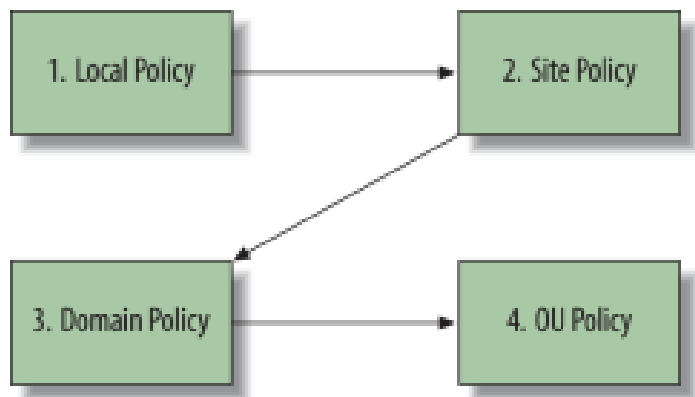
- По подразбиране една GPO въздейства на потребителите и компютрите в свързания обхват (частта от AD към която е свързана);

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (6)

➤ Приоритет и прилагане на много политики

- Правилата в груповите политики се прилагат в ред наричан LSDOU;
- Администраторът може да създаде приоритет за реда, в който се обработват, политиките, които са свързани с един и същ обект;
- GPO свързани с родителските домейни в дървото, не влияят на обектите разположени в домейни по-надолу в дървото;
- Дървото от домейни няма отношение към прилагането на GPO;

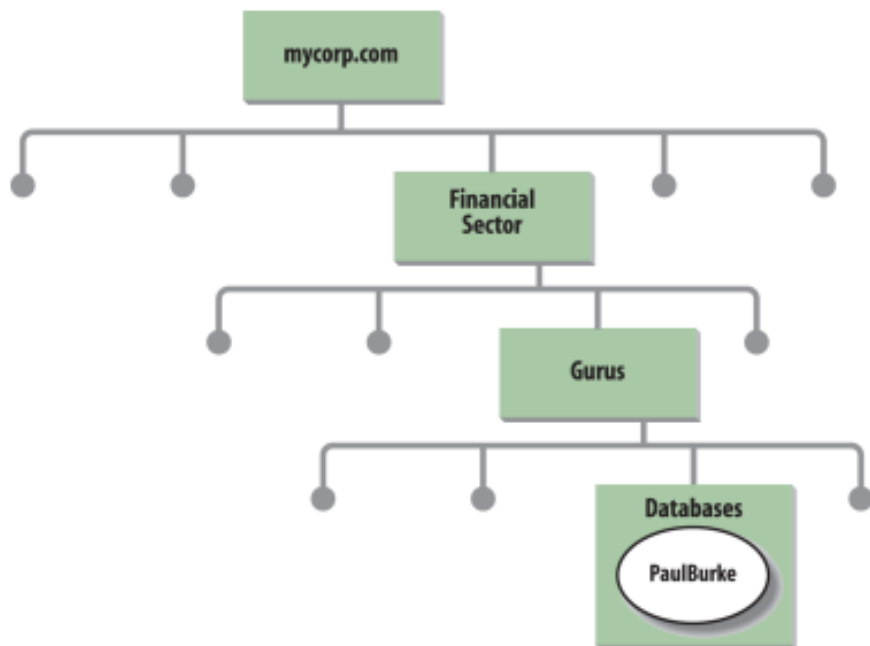


МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (7)

➤ Приоритет и прилагане на много политики

- Структурата и йерархията в OU влияе на прилагането на груповите политики;



Пример: При регистрация (*login*) на потребителя **PaulBurke** на компютъра си, който е в домейн *mycorp.com*:

1. Прилага се GPO на сайта
2. Прилага се GPO на домейн **mycorp.com**
3. Прилага се GPO на OU **Financial Sector**
4. Прилага се GPO на OU **Gurus**
5. Прилага се GPO на OU **Databases**

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (8)

➤ Прилагане на **computer** и **user** политики

- При стартиране на компютъра, всички GPO на сайта, които имат зададени политики за компютър се изпълняват в приоритетен ред и по правилото LSDOU. Политиките свързани с потребител се игнорират;
- След като потребителят извърши *login*, тогава се изпълняват политиките на GPO свързани с потребителите;
- Политиките за сложност на паролата, блокиране на потребителя при неуспешна регистрация, срок на валидност на паролата и Kerberos, могат да бъдат задавани само на GPO свързани с домейна. Такива настройки на GPO, свързани с OU, влияят само на локалните за компютъра потребителски акаунти;

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (9)

➤ Правила за наследяване на GPO в OU

- Ако има конфигурирана GPO на по-високо ниво и няма такава на по-ниските нива, то ниските нива **наследяват** политиките на родителските единици;
- Ако има конфигурирана GPO на по-високо ниво, както и на по-ниските нива, но няма стойности, които са в противоречие, то ниските нива **наследяват** политиките на родителските единици, но **прилагат и собствените си политики** (пример: ако има настроени *login scripts* ще се изпълнят последователно);
- Ако има конфигурирана GPO на по-високо ниво, както и на по-ниските нива, но има стойности, които са в противоречие, то ниските нива **няма да наследят** политиките на родителските единици и ще приложат собствените си политики;

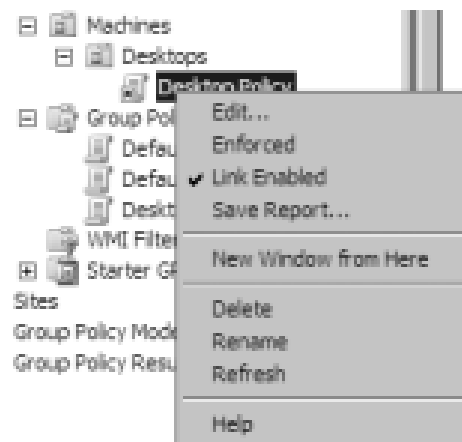
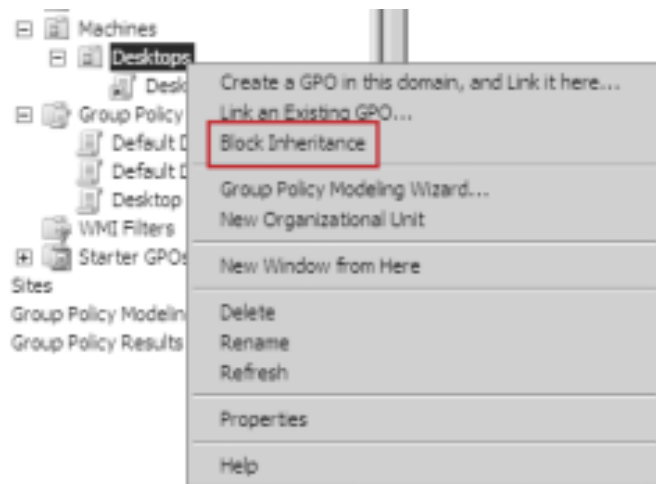
доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (10)

➤ Правила за наследяване на GPO в OU

- **Block inheritance** – блокира наследяването на GPO от по-горните нива, само ако не е избрано *Enforced*;
- **Enforce inheritance** – предизвиква наследяване на нейното GPO на по-ниските нива, дори ако има конфликтни стойности и на по-ниското ниво е избрано *Block inheritance*;



МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (11)

➤ Настройки за прилагане на GPO

- Ако ключа **System\Group Policy=0** - обновяване на всеки 7 сек!!!
По подразбиране DC обновява политиките си през 5 минути, а работните станции и другите сървъри през 90 минути;
- *gpupdate & gpresult*;

Computer group policy refresh registry values

Registry value name	Description
GroupPolicyRefreshTime	Description: refresh interval for domain members Data type: REG_DWORD Valid range: 0 – 64,800 minutes
GroupPolicyRefreshTimeOffset	Description: offset interval for domain members Data type: REG_DWORD Valid range: 0 – 1,440 minutes
GroupPolicyRefreshTimeDC	Description: refresh interval for domain controllers Data type: REG_DWORD Valid range: 0 – 64,800 minutes
GroupPolicyRefreshTimeOffsetDC	Description: offset interval for domain controllers Data type: REG_DWORD Valid range: 0 – 1,440 minutes

User group policy refresh values

Registry value name	Description
GroupPolicyRefreshTime	Description: refresh interval for users Data type: REG_DWORD Valid range: 0 – 64,800 minutes
GroupPolicyRefreshTimeOffset	Description: offset interval for users Data type: REG_DWORD Valid range: 0 – 1,440 minutes.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (12)

➤ Забавяния при прилагане на GPO

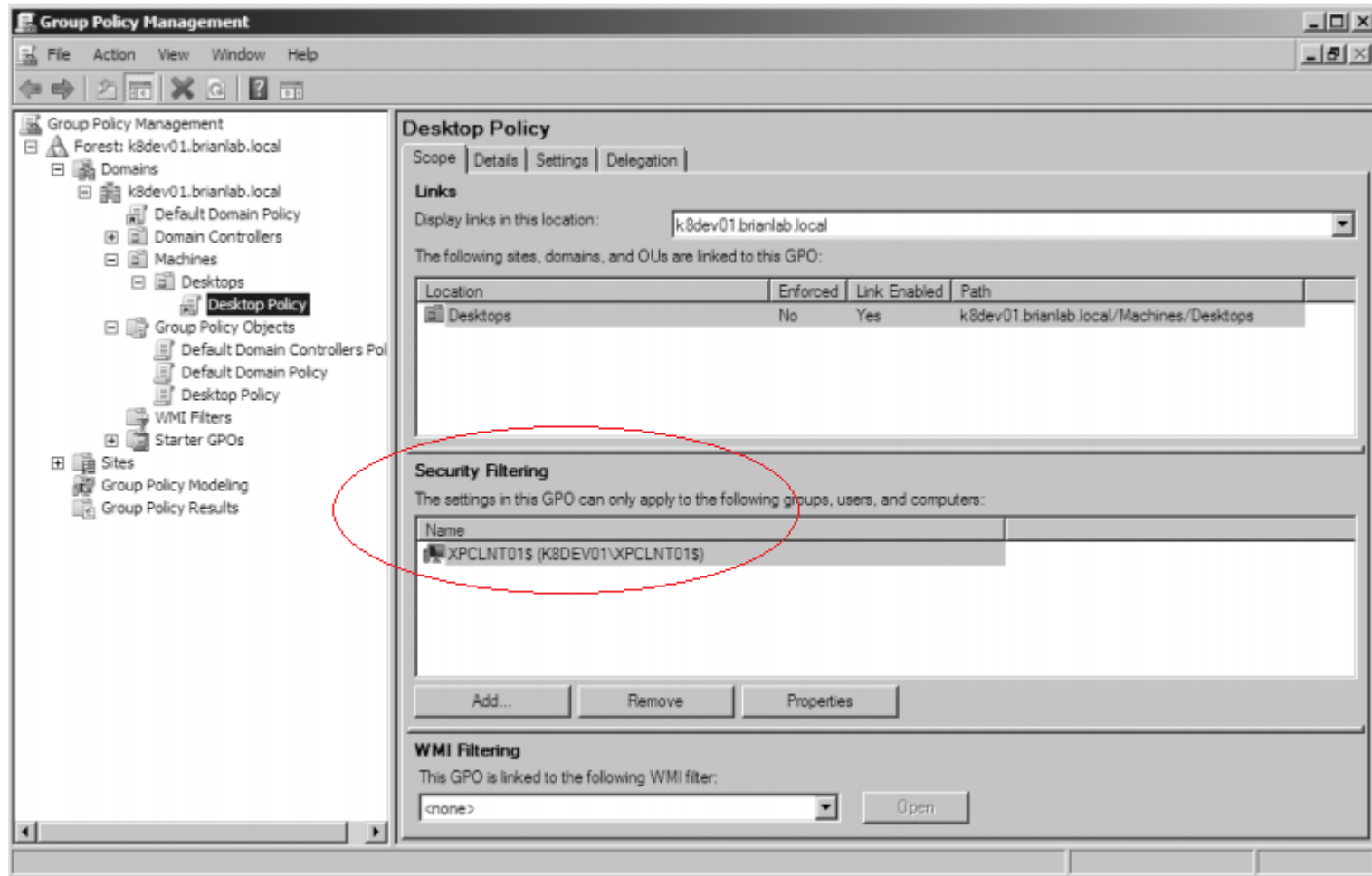
- Ако политиките са голям брой. Майкрософт препоръчва броят на нивата на OU да не е повече от 10;
- Ако една политика е свързана с множество домейни – трябва да се достъпи SYSVOL share в домейн контролера на домейна, в който е създадена съответната GPO;
- Ако се използват site GPO – тя се съхранява в домейн контролера, който е за кореновия домейн на дървото, което може да доведе до забавяне свързано с по-ниската скорост на WAN връзките;
- Може да се задава критерий за „бавна линия“;

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (13)

➤ Управление на прилагане на GPO чрез ACL



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Групови политики (15)

➤ Конфигуриране и управление на GPO

- *Group Policy Management Console (GPMC)* – проследяване, свързване на GPO към обекти на AD, функции за: import, export, backup restore, delete control, reports;
- *Group Policy Management Editor (GPME)* – редактиране на съдържанието на GPO;

МРЕЖОВО АДМИНИСТРИРАНЕ

NTFS Permissions (1)

➤ Стандартни (*basic*) разрешения за файлове и директории

- Full Control
- Modify
- Read & Execute
- Read
- Write

Permission	Meaning for Folders	Meaning for Files
Read	Permits viewing and listing of files and subfolders	Permits viewing or accessing of the file's contents
Write	Permits adding of files and subfolders	Permits writing to a file
Read & Execute	Permits viewing and listing of files and subfolders as well as executing of files; inherited by files and folders	Permits viewing and accessing of the file's contents as well as executing of the file
List Folder Contents	Permits viewing and listing of files and subfolders as well as executing of files; inherited by folders only	N/A
Modify	Permits reading and writing of files and subfolders; allows deletion of the folder	Permits reading and writing of the file; allows deletion of the file
Full Control	Permits reading, writing, changing, and deleting of files and subfolders	Permits reading, writing, changing and deleting of the file

доц. д-р инж. Росен Радков

NTFS Permissions (2)

➤ Разширени (*advanced*) разрешения за файлове и директории

- Traverse Folder/Execute File (за директории/файлове)
- List Folder/Read Data (за директории/файлове)
- Read Attributes
- Read Extended Attributes
- Create Files/Write Data (за директории/файлове)
- Create Folders/Append Data (за директории/файлове)
- Write Attributes
- Write Extended Attributes
- Delete Subfolders and Files (за директории)
- Read Permissions
- Change Permissions
- Take Ownership

МРЕЖОВО АДМИНИСТРИРАНЕ

NTFS Permissions

Special Permissions	Full Control	Modify	Read & Execute	List Folder Contents (folders only)	Read	Write
Traverse Folder/Execute File	x	x	x	x		
List Folder/Read Data	x	x	x	x	x	
Read Attributes	x	x	x	x	x	
Read Extended Attributes	x	x	x	x	x	
Create Files/Write Data	x	x				x
Create Folders/Append Data	x	x				x
Write Attributes	x	x				x
Write Extended Attributes	x	x				x
Delete Subfolders and Files	x					
Delete	x	x				
Read Permissions	x	x	x	x	x	x
Change Permissions	x					
Take Ownership	x					
Synchronize	x	x	x	x	x	x

доц. д-р инж. Росен Радков

NTFS Permissions (3)

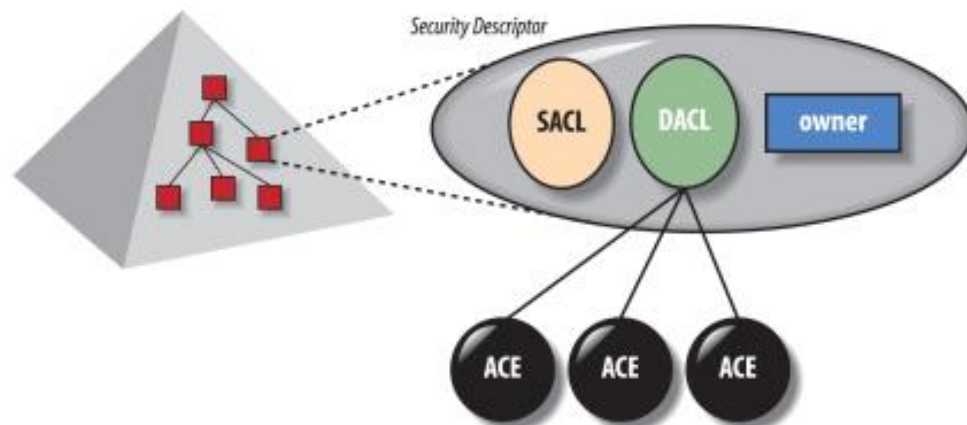
➤ Действие на разрешенията в зависимост от начина на назначаване. ОС ги оценява в ред 1-4 и първото разрешение, което съвпада с назначеното е валидно.

1. Explicit Deny
2. Explicit Allow
3. Inherited Deny
4. Inherited Allow

Пример: ако на даден файл, по механизма на наследяване, е определено разрешение *Denied Read (inherited)*, но изрично му е определено разрешение *Allow Read (explicit)*, то в резултат ще бъде валидно разрешението *Allow Read*.

МРЕЖОВО АДМИНИСТРИРАНЕ

Permissions в Active Directory



- Използват се за определяне на правата и привилегиите на обектите в AD;

SACL – System ACL

DACL – Discretionary ACL

ACE – Access Control Entry

- Разрешенията в AD се назначават по същия начин както при назначаването им на файлове и директории;
- В атрибута **nTSecurityDescriptor** на обекта, се съхранява стойност *security descriptor* (SD), където се пази цялата информация описваща назначените елементи за неговата защита (security);

доц. д-р инж. Росен Радков

Permissions в Active Directory

- **System ACL** – определя разрешенията за достъп до събитията свързани с успешно/неуспешно изпълнение на съответни събития (audit messages);
- **Discretionary ACL** - определя разрешенията за достъп до обект в AD, неговите характеристики и дъщерни обекти;
- Всяка една от посочените ACL съдържа колекция от access control entities (ACE), които се отнасят до неговите audit и permissions записи;
- ACE могат да се назначават както на обект, така и на някоя негова характеристика;

Permissions в Active Directory

➤ Информация, включена в permissions ACEs

- Trustee – SID на потребителя или групата, за когото се отнася;
- ACE Type - allow/deny;
- Object Type – schemaIDGUID за атрибут или клас на обект или rightsGuid за негова характеристика;
- Inherited Object Type - schemaIDGUID за типа на обекта, за които се отнася ACE, когато се задава стойност на атрибут;
- Access Mask – флаг, който описва типа на достъп: Read, Write, List, Create, Delete и т.н.;
- Flags – objectType и InheritedObjectType;

Всички разрешения в AD са базирани на тази ACE структура.

МРЕЖОВО АДМИНИСТРИРАНЕ

Permissions в Active Directory

➤ Default security descriptors

Trustee	Permission	Trustee	Permission
Domain\Domain Admins	Full Control	Domain\Cert Publishers	Read/Write userCertificate
Builtin\Account Operators	Full Control	Builtin\Windows Authorization Access Group	Read tokenGroupsGlobalAndUniversal
System	Full Control	Builtin\Terminal Server License Servers	Read/Write terminalServer
Self	Read Permissions List Contents Read Property List Object Read/Write Personal Information Read/Write Phone and Mail Options Read/Write Web Information Change Password Send As Receive As	Everyone	Change Password
Authenticated Users	Read Permissions Read General Information Read Public Information Read Personal Information Read Web Information		
Domain\RAS and IAS Servers	Read Account Restrictions Read Logon Information Read Group Membership Read Remote Access Information		

Всеки обект, дефиниран в схемата, има атрибута *defaultSecurityDescriptor*. Разрешенията по подразбиране са доста обширни в AD и са съставени изцяло от изрични ACE, така че те да заменят всяко наследено отричане (inherited deny)

Permissions в Active Directory

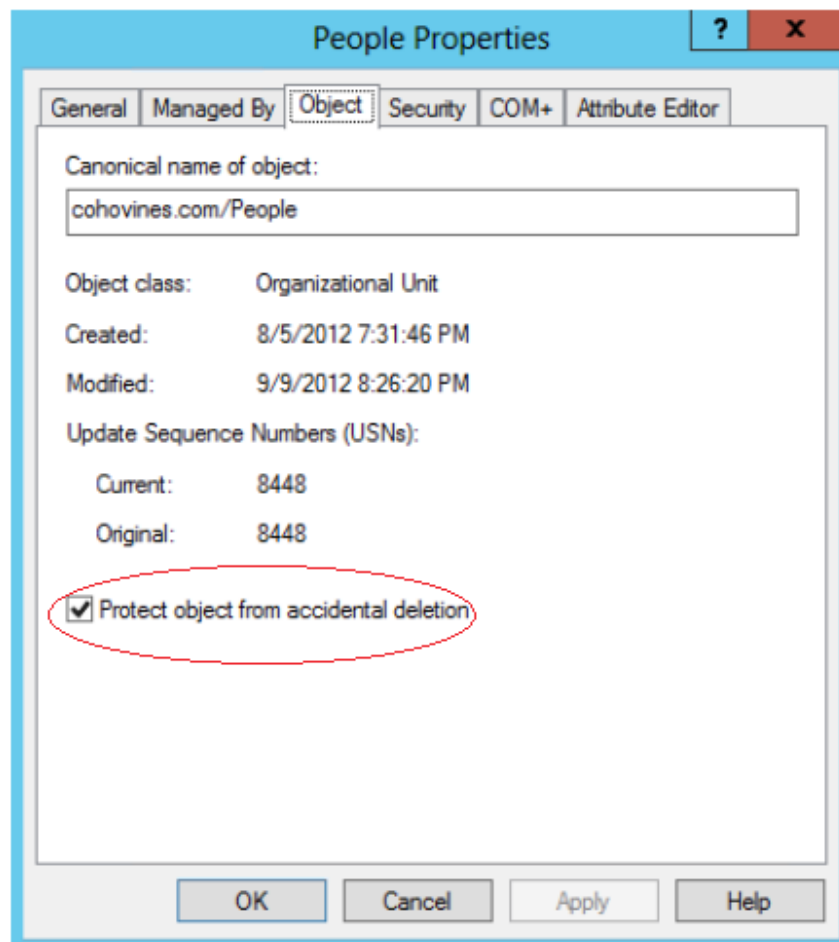
➤ **Бит за конфиденциалност** – когато този бит е установен, атрибутът става конфиденциален, т.е. само потребителите, които имат Read и Control Access разрешения ще могат да виждат атрибута. По подразбиране това са:

- Builtin\Administrators (inherited Full Control)
- Builtin\Account Operators (explicit Full Control)
- NT Authority\System (explicit Full Control)
- Domain\Domain Admins (explicit Full Control)
- Domain\Enterprise Admins (inherited Control Access)
- Object Creator\Owner (explicit Control Access)

МРЕЖОВО АДМИНИСТРИРАНЕ

Permissions в Active Directory

- Защита на обектите от изтриване (accidental deletion)



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Permissions в Active Directory

➤ Защита на обектите от изтриване (accidental deletion)

Permission Entry for People

Principal: Everyone [Select a principal](#)

Type: Deny

Applies to: This object only

Permissions:

☐ Full control	☐ Create msDS-AppData objects
☐ List contents	☒ Delete msDS-AppData objects
☐ Read all properties	☐ Create msDS-AzAdminManager objects
☐ Write all properties	☒ Delete msDS-AzAdminManager objects
☒ Delete	☐ Create msDS-GroupManagedServiceAccount objects
☒ Delete subtree	☒ Delete msDS-GroupManagedServiceAccount objects
☐ Read permissions	☐ Create msDS-ManagedServiceAccount objects
☐ Modify permissions	☒ Delete msDS-ManagedServiceAccount objects
☐ Modify owner	☐ Create msieee80211-Policy objects
☐ All validated writes	☒ Delete msieee80211-Policy objects
☐ All extended rights	☐ Create mslmaging-PSPs objects
☐ Create all child objects	☒ Delete mslmaging-PSPs objects
☒ Delete all child objects	☐ Create MSMQ Group objects
☐ Create account objects	☒ Delete MSMQ Group objects
☒ Delete account objects	☐ Create MSMQ Queue Alias objects
☐ Create applicationVersion objects	☒ Delete MSMQ Queue Alias objects

OK Cancel

доц. д-р инж. Росен Радков

Permissions в Active Directory

➤ Препоръчителни правила за назначаване на разрешения

- Да се използват групи, а не потребители винаги когато е възможно;
- Разрешенията, които се назначават на групите да не се дублират или да има минимално дублиране;
- Разширените разрешения да се променят само когато е абсолютно необходимо;
- Да не се забранява наследяването на разрешенията;
- Да се води дневник на промените;

МРЕЖОВО АДМИНИСТРИРАНЕ

Shares vs Permissions

- Споделянето на папки е начин да се осигури достъп до тях през компютърната мрежа
- Разрешенията, които са възможни са: *Full Control*, *Change* и *Read*;
- Тези разрешения не се отнасят за потребителите, които работят локално, на съответния компютър!!!;
- Кои разрешения са валидни?

SHARE PERMISSIONS	NTFS PERMISSIONS	USER ACCESS
Full Control Change Read	Full Control Modify Read & execute List folder contents Read Write	Full Control Modify Read & Execute List folder contents Read Write

SHARE PERMISSIONS	NTFS PERMISSIONS	USER ACCESS
Full Control Change Read	Full Control Modify Read & execute List folder contents Read Write	Full Control Modify Read & Execute List folder contents Read Write

МРЕЖОВО АДМИНИСТРИРАНЕ

Server Message Protocol (SMB) протокол

- Мрежов протокол от тип клиент-сървър, който се използва от приложенията за споделяне и достъп до файлове, принтери и др. чрез компютърна мрежа. Текущата версия на протокола е SMB 3.1.1 (2015г.), но има работещи устройства, които използват дори версия SMB 1.0 (1984г.), която през 2017 беше поразена от вирусите WannaCry и Petya, затова е препоръчително SMB 1.0 и следващата версия CIFS (1996г.) да бъдат забранени в конфигурацията на устройствата;
- Спада към групата на response-request протоколи, които обменят множество съобщения между клиента и сървъра за да изградят връзка;



Server Message Protocol (SMB) протокол

- Работи на приложно ниво;
- Използва TCP/IP (порт 445) като транспортен протокол. В по-старите версии се използват IPX, NetBIOS, NETBEUI, NetBIOS over TCP/IP (NBT);
- Samba (1992г.) е разработка с отворен код, прилагано в UNIX/Linux дистрибуции, използващо SMB протокол и позволяващо работа с Linux и Windows клиенти;

Server Message Protocol (SMB) протокол

➤ Характеристики

- Отдалечен достъп до файлове (Mapping network drives);
- Преглед на съдържанието на мрежовите устройства (network neighborhood);
- Автентикация;
- Поддръжка от различни операционни системи Windows, Unix, Linux, OS/2, Apple;

Server Message Protocol (SMB) протокол

➤ Начин на работа

- **Услуга за имена на компютрите чрез DNS или NetBIOS**

- ◆ Broadcast only (b-node) чрез UDP на port 137
- ◆ Чрез NetBIOS Name Server (NBNS) (p-node) чрез UDP на port 137
- ◆ Broadcast и NBNS след това, ако няма отговор (m-node)
- ◆ NBNS и broadcast, ако NBNS сървъра не отговаря (n-node)

- **Услуга за пренос на данни чрез сесия (чрез TCP на порт 139)**

- ◆ CALL
- ◆ LISTEN
- ◆ HANG UP
- ◆ SEND
- ◆ RECEIVE
- ◆ SESSION STATUS

Server Message Protocol (SMB) протокол

- Начин на работа
- Услуга за пренос на данни чрез дейтаграми (чрез UDP на порт 138)
- ◆ Ненадежден режим

МРЕЖОВО АДМИНИСТРИРАНЕ

БЛАГОДАРЯ ЗА ВНИМАНИЕТО!

доц. д-р инж. Росен Радков